

Universidad Nacional Mayor de San Marcos

Universidad del Perú. Decana de América

Facultad de Ingeniería de Sistemas e Informática

Escuela Profesional de Ingeniería de Software



Sistema Integral de Gestión de Garantías y Reparaciones

Trabajo como parte del curso de Seguridad de Software

Grupo 2, integrantes:

Diego ALVAREZ MORE

Diego Andre FALLA GALLEGOS

Marko Jhunior RIQUE GARCIA

Jocelyn Estrella SOTELO ARCE

Pedro Sebastián VASQUEZ GONZALES

Profesor:

Mario Agustin HUAPAYA CHUMPITAZ

LIMA – PERÚ

2024

Índice

Análisis de desarrollo de software seguro	3
Clasificación de activos	3
Casos de abuso	4
Caso de Abuso 2: Modificación No Autorizada de Solicitudes	4
Caso de Abuso 4: Manipulación de Plazos y Garantías	5
Caso de Abuso 5: Saturación del Sistema (Ataque de Denegación de Servicio - DoS)	6
Requisitos funcionales	7
Requisitos de seguridad o historias de seguridad	8
Requisitos de privacidad o historias de privacidad	9
Análisis de riesgos	9
Priorización de requisitos	10
Especificación del Caso de Uso o descripción de historia de seguridad, privacidad	11
Diagrama de clases o el MER (Lógico y Físico) del producto software seguro	14
Diccionario de Datos	14
1. Cliente	14

Análisis de desarrollo de software seguro

Clasificación de activos

1.1. Activos Humanos

- **Desarrolladores Frontend:** Encargados de la implementación de la interfaz con ReactJS.
- **Desarrolladores Backend:** Responsables de la lógica del sistema en ASP.NET y la integración con PostgreSQL.
- **Administradores de Base de Datos (DBA):** Gestionan la integridad y seguridad de la base de datos PostgreSQL.
- **Ingenieros de Pruebas:** Aseguran que el sistema funcione correctamente mediante pruebas unitarias, de integración y aceptación.
- **Diseñadores UX/UI:** Diseñan interfaces que mejoren la experiencia del usuario.
- **Gerentes de Proyecto:** Encargados de la coordinación general y seguimiento del cronograma.

1.2 Activos de Información

- **Datos de Clientes:** Información personal y de contacto de los clientes que envían solicitudes de reparación y garantía.
- **Datos de Productos:** Detalles de los productos en garantía o que requieren reparación, como modelo, fecha de compra, número de serie, etc.
- **Documentación Técnica:** Instrucciones, manuales técnicos, y otros documentos relacionados con los productos y reparaciones.

- ***Solicitudes Emitidas:*** Historial de solicitudes de garantía y reparación, junto con su estado, fecha de emisión, y trabajador asignado.
- ***Cotizaciones Generadas:*** PDF de cotizaciones emitidas para reparaciones o servicios, con detalles del costo.
- ***Notificaciones de Plazos y Garantías Expiradas:*** Alertas generadas automáticamente por el sistema para notificar al usuario sobre plazos de entrega cercanos, garantías expiradas, y nuevas ventas.

1.3 Activos de Software

- ***Módulo de Gestión de Solicitudes:*** Software desarrollado específicamente para gestionar las solicitudes de garantía y reparación.
- ***Módulo de Cotizaciones:*** Software encargado de generar y gestionar las cotizaciones para las reparaciones, incluyendo la funcionalidad para crear PDFs.
- ***Módulo de Notificaciones:*** Sistema de software que genera y envía notificaciones automáticas sobre plazos de entrega, garantías expiradas, y nuevos eventos relacionados.
- ***Módulo de Seguimiento de Solicitudes:*** Componente que permite visualizar el estado de las solicitudes, trabajadores asignados y fechas relevantes.

Casos de abuso

Caso de Abuso 1: Acceso No Autorizado a la Plataforma

Actor: Usuario malintencionado (externo o interno).

Descripción: Un usuario no autorizado intenta acceder a la plataforma con credenciales robadas o mediante un ataque de fuerza bruta.

Consecuencias: Acceso a información sensible de los clientes, productos, y solicitudes de reparación. Modificación o eliminación de datos críticos.

Prevención:

- Implementación de autenticación multifactor (MFA).
- Políticas de contraseñas robustas.
- Bloqueo temporal de cuentas después de varios intentos fallidos de inicio de sesión.
- Monitoreo de intentos de acceso sospechosos.

Caso de Abuso 2: Modificación No Autorizada de Solicitudes

Actor: Usuario interno con malas intenciones o un atacante que ha obtenido acceso.

Descripción: Un usuario intenta modificar solicitudes de reparación o garantías sin los permisos adecuados, alterando detalles importantes como productos, estado de la solicitud o fechas de vencimiento de garantías.

Consecuencias: Información incorrecta en el sistema, lo que podría afectar el proceso de reparación o crear conflictos con los clientes.

Prevención:

- Implementación de controles de acceso basados en roles (RBAC).
- Auditoría y registro de todas las acciones realizadas en las solicitudes.
- Notificaciones automáticas al administrador en caso de cambios críticos.

Caso de abuso 3: Generación de Cotizaciones Fraudulentas

Actor: Usuario interno malintencionado o atacante con acceso a la cuenta de un usuario autorizado.

Descripción: Un usuario intenta generar cotizaciones fraudulentas, manipulando los precios o condiciones en favor de un tercero o para beneficio personal.

Consecuencias: Pérdida económica para la empresa y posibles conflictos con los clientes debido a cotizaciones incorrectas.

Prevención:

- Control estricto de permisos para la generación y modificación de cotizaciones.
- Registro de todas las cotizaciones generadas, incluyendo el usuario y la hora de la creación.
- Implementación de un sistema de revisión y aprobación para cotizaciones importantes.

Caso de Abuso 4: Manipulación de Plazos y Garantías

Actor: Usuario malintencionado (interno o externo).

Descripción: Un usuario con acceso intenta manipular los plazos de entrega o fechas de vencimiento de las garantías para favorecer o perjudicar a clientes.

Consecuencias: Afectación del servicio, generando que algunos clientes reciban notificaciones incorrectas o que se pierdan plazos importantes.

Prevención:

- Verificación y control estricto de la edición de plazos y vencimientos de garantías.
- Notificaciones automáticas al administrador ante cambios inusuales o sospechosos en los plazos.
- Auditoría y registro de todas las modificaciones a fechas de entrega o vencimientos.

Caso de Abuso 5: Saturación del Sistema (Ataque de Denegación de Servicio - DoS)

Actor: Atacante externo.

Descripción: Un atacante intenta sobrecargar el sistema con múltiples solicitudes simultáneas, lo que podría hacer que el sistema no responda y deje de estar disponible para los usuarios legítimos.

Consecuencias: Interrupción del servicio, afectando la operación normal de la plataforma y generando insatisfacción entre los clientes.

Prevención:

- Implementación de un sistema de balanceo de carga para manejar grandes volúmenes de tráfico.
- Monitoreo en tiempo real del rendimiento del sistema para detectar y mitigar ataques DoS.
- Implementación de límites de tasa (rate limiting) para solicitudes al servidor.

Caso de abuso 6: Robo de Identidad del Cliente

Actor: Usuario malintencionado

Descripción: Un atacante intenta hacerse pasar por un cliente legítimo para manipular solicitudes, obtener reparaciones gratuitas o acceder a información de garantías de otros clientes.

Consecuencias: Pérdida de confianza por parte de los clientes, acceso no autorizado a datos confidenciales y posibles repercusiones legales.

Prevención:

- Implementación de autenticación robusta para los clientes.
- Uso de preguntas de seguridad o validación adicional para cambios importantes en las solicitudes de reparación o garantía.
- Monitoreo de patrones de comportamiento sospechosos en las cuentas de clientes.

Requisitos funcionales

Requisitos Funcionales	Descripción
RF001	El sistema debe permitir a los usuarios enviar solicitudes de garantía y reparación, adjuntando los datos requeridos del cliente y del producto para iniciar el proceso.
RF002	El sistema debe permitir a los usuarios modificar las solicitudes de reparación, adjuntar documentación técnica, y generar cotizaciones de manera automática.
RF003	El sistema debe ofrecer una vista detallada del listado de solicitudes emitidas, permitiendo al usuario ver el estado, la fecha de emisión, el trabajador asignado, y los datos de contacto del cliente.
RF004	El sistema debe implementar un sistema de notificaciones que informe al usuario sobre plazos de entrega cercanos, garantías expiradas, nuevas ventas, y otros eventos importantes.
RF005	El sistema debe generar automáticamente cotizaciones basadas en los datos ingresados en la solicitud, como el tipo de producto y el problema informado.
RF006	El sistema debe generar un historial de modificaciones de cada solicitud, registrando quién realizó qué cambios y cuándo, para mantener un registro detallado.
RF007	El sistema debe permitir la generación de solicitudes y cotizaciones en formato PDF que incluya la información relevante.

Requisitos de seguridad o historias de seguridad

Requisitos de Seguridad	Descripción
RS001	El sistema debe permitir a los usuarios autenticarse mediante un inicio de sesión seguro con verificación de credenciales utilizando JWT (JSON Web Token) para garantizar sesiones seguras.
RS002	El sistema debe implementar cifrado SSL/TLS para proteger la transmisión de datos entre los usuarios y el servidor, asegurando que la información confidencial (como datos del cliente y del producto) esté protegida en tránsito.
RS003	El sistema debe cifrar las contraseñas de los usuarios utilizando algoritmos de hash seguros (bcrypt, por ejemplo) para evitar que las contraseñas sean almacenadas en texto plano en la base de datos.
RS004	El sistema debe implementar protección contra ataques de fuerza bruta, limitando la cantidad de intentos fallidos de inicio de sesión y utilizando mecanismos como CAPTCHA o bloqueo temporal de cuentas.
RS005	El sistema debe implementar políticas de almacenamiento seguro para los documentos adjuntos (como imágenes, facturas, cotizaciones en PDF), asegurando que solo los usuarios autorizados puedan acceder y descargar esos archivos.
RS006	El sistema debe proteger los datos sensibles (como información personal de los clientes y cotizaciones) utilizando cifrado en reposo, asegurando que los datos almacenados en la base de datos no puedan ser accedidos por usuarios no autorizados o en caso de una brecha de seguridad.
RS007	El sistema debe incluir medidas de prevención contra inyecciones SQL mediante el uso de consultas preparadas o un ORM (Object-Relational Mapping), evitando la ejecución de comandos maliciosos desde entradas de usuarios.
RS008	El sistema debe incluir la opción de cerrar sesión automáticamente después de un periodo de inactividad, protegiendo las sesiones de usuarios que se dejen abiertas por accidente en dispositivos públicos o compartidos.
RS009	El sistema debe proteger las API que interactúan con la plataforma

	utilizando autenticación segura y tokens de acceso para asegurar que solo aplicaciones autorizadas puedan acceder a los datos del sistema.
--	--

Requisitos de privacidad o historias de privacidad

Confidencialidad de los Datos del Cliente:

- El sistema debe garantizar que los datos personales de los clientes (como nombre, dirección, teléfono, correo electrónico, etc.) sean almacenados de forma segura y solo accesibles por el personal autorizado.
- Debe implementarse un cifrado en la base de datos para proteger los datos sensibles tanto en reposo como en tránsito.

Control de Acceso Basado en Roles:

- Los usuarios del sistema deben tener diferentes niveles de acceso dependiendo de su rol (por ejemplo, administrador, técnico, cliente).
- Los datos sensibles solo deben ser accesibles para aquellos con el nivel de permiso adecuado.

Anonimización de Datos para Reportes:

- Los informes generados para el análisis o el seguimiento de solicitudes deben anonimizar los datos personales, mostrando solo la información necesaria para la operación.

Transparencia en el Uso de Datos:

El sistema debe proporcionar a los usuarios información clara y comprensible sobre cómo se recopilan, utilizan, almacenan y comparten sus datos personales.

Análisis de riesgos

Acceso No Autorizado a Datos Sensibles

- **Descripción:** Un usuario no autorizado puede acceder a datos personales de los clientes o información confidencial del sistema.
- **Impacto:** Alto. Podría resultar en violaciones de privacidad, pérdida de reputación y sanciones legales.
- **Probabilidad:** Media. Existe la posibilidad de un acceso no autorizado debido a errores de configuración o fallas en el control de acceso.
- **Mitigación:** Implementar autenticación multifactor (MFA), controles de acceso basados en roles (RBAC), y cifrado de datos tanto en reposo como en tránsito.

Pérdida de Datos por Fallos Técnicos o Errores Humanos

- **Descripción:** Los datos almacenados en el sistema podrían perderse debido a fallos de hardware, errores de software o manipulaciones incorrectas.
- **Impacto:** Alto. La pérdida de datos podría afectar la operación del sistema y la satisfacción del cliente.
- **Probabilidad:** Media. La probabilidad es moderada debido a posibles fallos técnicos o errores humanos.
- **Mitigación:** Implementar un sistema de copias de seguridad regular, mantener registros de auditoría y realizar pruebas periódicas de recuperación de datos.

Ataque de Software Malicioso (Malware)

- **Descripción:** El sistema podría ser comprometido por malware, como ransomware o troyanos, que podrían dañar los datos o interrumpir el servicio.
- **Impacto:** Alto. El ataque puede llevar a la pérdida de datos o a la inoperabilidad del sistema.
- **Probabilidad:** Media. Los ataques de malware son comunes y podrían ocurrir debido a descuidos en la seguridad.
- **Mitigación:** Utilizar software antivirus actualizado, aplicar parches de seguridad regularmente y educar a los usuarios sobre prácticas seguras.

Priorización de requisitos

Alta Prioridad:

- **RF001:** Permitir a los usuarios enviar solicitudes de garantía y reparación (es el núcleo del sistema).
- **RF003:** Vista detallada del listado de solicitudes (clave para la gestión diaria).
- **RS001:** Inicio de sesión seguro con JWT (para garantizar la seguridad desde el inicio).
- **RS002:** Implementar cifrado SSL/TLS para proteger la transmisión de datos.
- **RS005:** Almacenamiento seguro de documentos adjuntos (para proteger la integridad de la información crítica).

Media Prioridad:

- **RF002:** Modificación de solicitudes, adjuntar documentación técnica y generar cotizaciones (importante para las iteraciones de solicitudes).
- **RF005:** Generación automática de cotizaciones (clave para la eficiencia, pero puede implementarse después de la funcionalidad básica).
- **RS003:** Cifrado de contraseñas utilizando algoritmos de hash seguros (prioritario para seguridad, pero posterior al inicio de sesión).
- **RS007:** Protección contra inyecciones SQL (asegura la integridad del sistema, pero una vez que se tiene un prototipo funcional).

Baja Prioridad:

- **RF006:** Historial de modificaciones de solicitudes (importante para auditorías, pero no esencial en la primera versión).
- **RF007:** Generación de solicitudes y cotizaciones en PDF (aunque necesario, puede ser añadido en una segunda iteración).
- **RS004:** Protección contra ataques de fuerza bruta (relevante a largo plazo, pero puede agregarse tras el desarrollo inicial).
- **RS006:** Cifrado en reposo (importante, pero puede implementarse una vez que los datos están gestionados y almacenados).

Especificación del Caso de Uso o descripción de historia de seguridad, privacidad

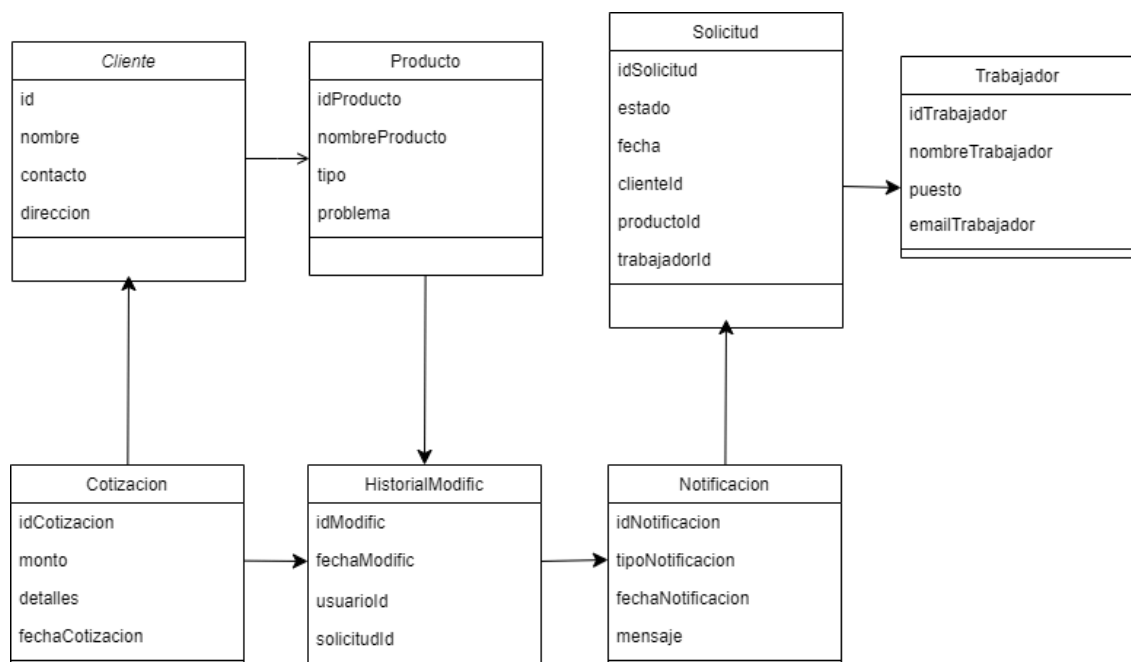
Caso de Uso: Autenticación Segura y Protección de Datos Personales

- **Título:** Autenticación Segura y Protección de Datos del Usuario
- **Descripción:** El sistema debe garantizar que solo usuarios autenticados puedan acceder a la plataforma, y que todos los datos sensibles del cliente, productos y documentos estén debidamente protegidos tanto en tránsito como en reposo.
- **Actores:**
 - Usuario final (cliente o empleado).
 - Sistema de autenticación (JWT).
 - API.
- **Precondiciones:**
 - El usuario debe estar registrado en el sistema con un nombre de usuario y una contraseña.
 - El sistema debe contar con un mecanismo de autenticación seguro que utilice tokens JWT.
 - Todos los canales de comunicación entre el cliente y el servidor deben estar protegidos con SSL/TLS.
- **Flujo principal:**
 - El usuario accede a la plataforma.
 - El sistema solicita credenciales de inicio de sesión.
 - El usuario ingresa su nombre de usuario y contraseña.

- El sistema verifica las credenciales utilizando un algoritmo de hash seguro (bcrypt).
- Si las credenciales son correctas, se genera un token JWT, que será enviado al usuario.
- El usuario interactúa con la plataforma enviando solicitudes autenticadas con el token.
- El sistema protege las solicitudes mediante cifrado SSL/TLS.
- **Postcondiciones:**
 - El usuario solo podrá acceder a la plataforma y realizar acciones si está autenticado correctamente.
 - Los datos sensibles intercambiados entre el cliente y el servidor estarán cifrados y protegidos en tránsito.
- **Requisitos de seguridad asociados:**
 - **RS001:** Autenticación segura mediante JWT.
 - **RS002:** Cifrado SSL/TLS en todas las comunicaciones.
 - **RS003:** Contraseñas almacenadas con algoritmos seguros.
 - **RS005:** Protección y acceso restringido a documentos adjuntos.
 - **RS006:** Cifrado de datos sensibles en reposo.
- **Consideraciones de privacidad:**
 - Los datos personales (nombres, direcciones, teléfonos) deben estar cifrados en la base de datos.
 - Los tokens JWT deben tener un tiempo de expiración razonable para evitar vulnerabilidades derivadas de sesiones prolongadas.

- Implementar un sistema de cierre de sesión automático tras un periodo de inactividad prolongada, protegiendo a los usuarios en dispositivos compartidos.

Diagrama de clases o el MER (Lógico y Físico) del producto software seguro



Diccionario de Datos

1. Cliente

Campo	Tipo	Descripción	Restricciones
-------	------	-------------	---------------

id	Long	identificador del cliente	Clave primaria
nombre	String	Nombre del cliente	No nulo
contacto	String	Información de contacto	No nulo
dirección	String	Dirección del cliente	Opcional

2. Producto

Campo	Tipo	Descripción	Restricciones
idProducto	Long	Identificador único del producto	Clave primaria
nombreProducto	String	Nombre del producto	No nulo
tipo	String	Tipo de producto	No nulo
problema	String	Problema descrito del producto	Opcional

3. Solicitud

Campo	Tipo	Descripción	Restricciones
idSolicitud	Long	Identificador único de la solicitud	Clave primaria
estado	String	Estado actual de la solicitud	No nulo
fecha	Date	Fecha en que se realizó la solicitud	No nulo
clienteId	Long	Identificador del cliente asociado	Clave foránea
productoId	Long	Identificador del producto asociado	Clave foránea

trabajadorId	Long	Identificador del trabajador asignado	Clave foránea
--------------	------	---------------------------------------	---------------

4. Trabajador

Campo	Tipo	Descripción	Restricciones
idTrabajador	Long	Identificador unico del trabajador	Clave primaria
nombreTrabajador	String	Nombre del trabajador	No nulo
puesto	String	Puesto o rol del trabajador	Opcional
emailTrabajador	String	Correo electronico del trabajador	Opcional

5. Cotización

Campo	Tipo	Descripción	Restricciones
idCotizacion	Long	Identificador único de la cotización	Clave primaria
monto	Double	Monto calculado para la cotización	No nulo
detalles	String	Detalles sobre la cotización	Opcional
fechaCotizacion	Date	Fecha en que se genero la cotización	No nulo
solicitudId	Long	Identificador de la solicitud asociada	Clave foránea

6. Historial de Modificaciones

Campo	Tipo	Descripción	Restricciones
idModific	Long	Identificador	Clave primaria

		único del historial de modificaciones	
fechaModific	Date	Fecha de la modificación	No nulo
usuariold	Long	Identificador del usuario que hizo el cambio	Opcional
solicitudId	Long	Identificador de la solicitud modificada	Clave foránea
cambios	String	Descripción de los cambios realizados	Opcional

7. Notificación

Campo	Tipo	Descripción	Restricciones
idNotificacion	Long	Identificador único de la notificación	Clave primaria
tipo	String	Tipo de notificación	No nulo
fechaNotificacion	Date	Fecha en que se genero la notificación	No nulo
mensaje	String	Mensaje de la notificación	No nulo